

Section 10

Industrial Security (Bachelor)



Section 10 – Incident Response and Recovery

Incident Response and Recovery

Lecture Notes

Department of Computer Science

2026-05-17

Industrial Security (Bachelor)

Section 10

Industrial Security (Bachelor)



Section 10 – Incident Response and Recovery

Incident Response and Recovery
Lecture Notes
Department of Computer Science

- 1 OT-Specific Considerations
- 2 Forensics and Reporting
- 3 Exercises and Continuity

2026-05-17

By the end of this section you will be able to

- Distinguish IT and OT considerations in incident response.
- Build a basic OT IR playbook.
- Understand forensic acquisition options on ICS devices.
- Plan a tabletop exercise.

-  By the end of this section you will be able to
- Distinguish IT and OT considerations in incident response.
 - Build a basic OT IR playbook.
 - Understand forensic acquisition options on ICS devices.
 - Plan a tabletop exercise.

1

OT-Specific Considerations

Safety first – a wrong response may cause a worse incident

Don't pull the cable – losing visibility can blind operators

Process owners must be in the IR loop, not just IT

Some forensic actions (memory dump on running PLC) are infeasible

Containment may require manual fall-back to local control

2026-05-17

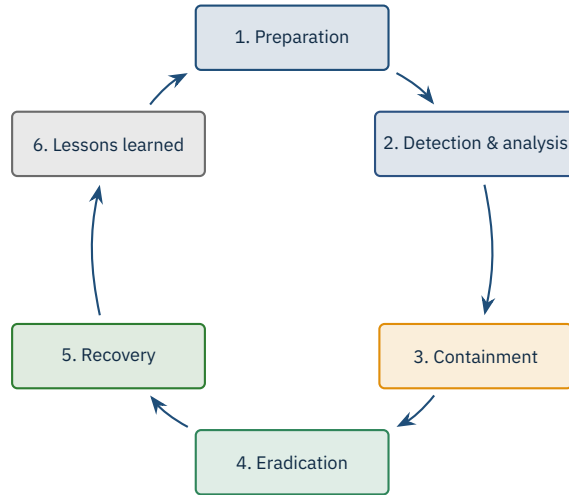
Industrial Security (Bachelor)
└ OT-Specific Considerations

└ Why OT IR Is Different

Frame the whole section with this slide: OT IR inherits the IT playbook but inverts its priorities. In IT we yank the cable; in OT the cable *is* the control loop, and pulling it can blind operators or trip a safety system that is worse than the original incident. Tell them the common misconception “just call the SOC” — a generic SOC analyst has never seen a PLC and will happily quarantine the HMI right before a batch reactor needs an operator intervention. Anchor the lecture in one rule: safety first, then process continuity, then forensics. Ask the room: at a refinery, who has the authority to call “shut down the unit”? It is almost never security, and that decision-rights question is the heart of OT IR.

Why OT IR Is Different

- Safety first – a wrong response may cause a worse incident
- Don't pull the cable – losing visibility can blind operators
- Process owners must be in the IR loop, not just IT
- Some forensic actions (memory dump on running PLC) are infeasible
- Containment may require manual fall-back to local control

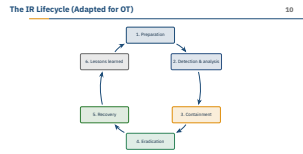


2026-05-17

Industrial Security (Bachelor)
└ OT-Specific Considerations

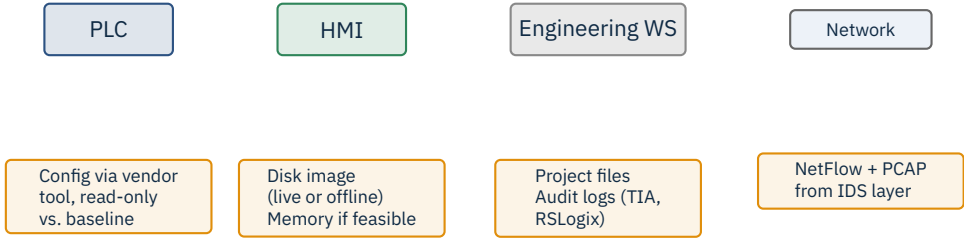
└ The IR Lifecycle (Adapted for OT)

This is the NIST SP 800-61 Rev. 2 lifecycle, but read every phase through an OT lens. Preparation in OT means knowing your process: golden PLC project files, signed firmware hashes, a list of who can authorise a shutdown. Detection lags in OT — many plants found out about Industroyer-style payloads only because operators noticed breakers tripping, not because an EDR alerted. Containment and eradication look nothing like IT: you cannot just wipe and re-image a Safety Instrumented System, you negotiate a controlled outage during a planned maintenance window. The loop matters: lessons learned must feed back into preparation, otherwise the next incident repeats the last one. Stress that the cycle never stops — it is continuous, not episodic.



2

Forensics and Reporting



Chain of custody from minute one.

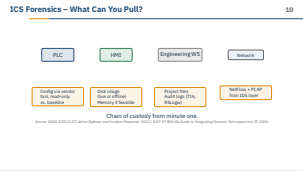
Source: SANS ICS515 ICS Active Defense and Incident Response, 2024 | NIST SP 800-86 Guide to Integrating Forensic Techniques into IR, 2006.

2026-05-17

Industrial Security (Bachelor)
└ Forensics and Reporting

└ ICS Forensics – What Can You Pull?

Walk left to right and be honest about what is actually feasible. The PLC almost never gives you a clean memory image — most vendors have no documented dump interface, so you compare the running configuration against your last signed baseline using the vendor tool (TIA Portal, Studio 5000, Unity Pro). The HMI is the easiest win: it is a Windows box, so disk image and volatile memory if the process tolerates it. Engineering workstations are forensic gold — TIA audit trails and project file timestamps often show who downloaded what to which PLC and when. The single most valuable artefact is the network capture, because it is the only place you can prove a malicious Modbus or S7 write actually happened. Push the chain-of-custody point: write down who touched what, when, with which hash, from minute one, or the report is worthless in court.



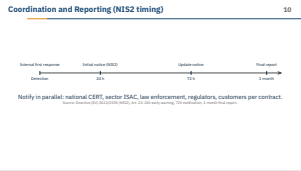


Notify in parallel: national CERT, sector ISAC, law enforcement, regulators, customers per contract.
Source: Directive (EU) 2022/2555 (NIS2), Art. 23: 24h early warning, 72h notification, 1-month final report.

2026-05-17

- Industrial Security (Bachelor)
 - Forensics and Reporting
 - Coordination and Reporting (NIS2 timing)

The 24-hour early warning is much shorter than people realise — in practice you have detected the incident, woken the on-call, and you still need to file something before lunch tomorrow. Stress that “early warning” in NIS2 Art. 23 is not the full report; it is the heads-up that something is happening, and regulators expect it even when you do not yet know root cause. The 72-hour update is where you commit to a working hypothesis, and the one-month final report is where you close the loop with impact and corrective actions. Common mistake in industry: teams treat 24 h as “we still have a day to investigate” and then miss the deadline because nobody owned the notification. Build the notification path before the incident: who has the credentials for the BSI Meldeportal, who signs off, who calls the customer? Mention that fines for late notification can exceed the cost of the incident itself.



3

Exercises and Continuity

Ransomware encrypts the Historian

Insider exfiltrates PLC programs before resignation

Nation-state intrusion into Safety Instrumented System

Vendor remote-access account is compromised

Suspicious unsolicited Modbus writes from IT subnet

2026-05-17

Industrial Security (Bachelor)
└ Exercises and Continuity

└ Tabletop Exercise Scenarios

Pick one scenario per quarter and rehearse it with the actual on-call people, not a slide deck. The historian-ransomware scenario is the most common one in industry because the historian sits on the IT/OT boundary and runs Windows — ask the room what they lose if the last 30 days of trends are gone. The SIS intrusion is the TRITON / Triconex flashback; it is rare but catastrophic, and the right answer is usually “stop and call the vendor”, not “patch live”. The vendor remote-access scenario tracks the 2021 Oldsmar water plant playbook: a third party TeamViewer session with a shared password. Use these to surface decision rights: who declares the incident, who calls the regulator, who tells the plant manager to switch to manual? The whole point of a tabletop is to find out that nobody knows — and then fix it on paper, not in production.

Tabletop Exercise Scenarios	
	Ransomware encrypts the Historian
	Insider exfiltrates PLC programs before resignation
	Nation-state intrusion into Safety Instrumented System
	Vendor remote-access account is compromised
	Suspicious unsolicited Modbus writes from IT subnet



Rehearse

Plans must be rehearsed. Paper plans fail under stress.

2026-05-17

Industrial Security (Bachelor)
└ Exercises and Continuity

└ Business Continuity & Recovery

Define both terms cleanly: RTO is “how long can we be down”, RPO is “how much data/state can we afford to lose”. In OT, RPO often means “how stale can the last good PLC project file be” — and the misconception “we restore from backup” falls apart fast when you ask which backup of the PLC program, and whether anyone verified it boots. Manual fall-back is the OT-specific lever: many plants can run for hours on local control panels while the network is being cleaned, but only if operators have practised it recently. Cold spares matter because vendor lead times on legacy controllers can be 6–18 months — shelf stock is a security control. Push the rehearse point hard: a plan that has never been executed is a wish, not a plan. Ask the room about their bachelor thesis lab: do they have a snapshot of the PLC program they could restore right now?



Rehearse

Plans must be rehearsed. Paper plans fail under stress.

Activity	Operator	Control Eng	OT Security	Plant Mgr
Detect anomaly	R	C	I	I
Assess process risk	C	R	C	A
Contain (segment FW)	I	C	R	A
Stop production	C	C	C	A/R
Forensic capture	I	C	R	I
External notification	I	I	C	A

R = Responsible, A = Accountable, C = Consulted, I = Informed.

2026-05-17

Industrial Security (Bachelor)
└ Exercises and Continuity

└ IR Roles (RACI)

Walk one row at a time and note where the role differs from a generic IT RACI. The crucial line is “Stop production” — accountable is the plant manager, never security, because the cost of an unplanned shutdown can be in the hundreds of thousands of euros per hour. “Forensic capture” is OT security responsible but control engineering consulted, because pulling a PCAP from a controller-facing switch can disturb the process if done wrong. Operators detect more anomalies than any IDS in OT because they live with the process; if your RACI does not list them as responsible for detection, the table is wrong. Common failure mode: organisations copy an IT RACI and forget the operator entirely, then wonder why nothing gets escalated. Ask the room to challenge any cell — if a student disagrees, the discussion is the lesson.

IR Roles (RACI)

Activity	Operator	Control Eng	OT Security	Plant Mgr
Detect anomaly	R	C	I	I
Assess process risk	C	R	C	A
Contain (segment FW)	I	C	R	A
Stop production	C	C	C	A/R
Forensic capture	I	C	R	I
External notification	I	I	C	A

R = Responsible, A = Accountable, C = Consulted, I = Informed.

Wireshark / tshark

Zeek

Suricata + ICS rules

Malcolm (full stack)

NetworkMiner

tcpdump

Workflow

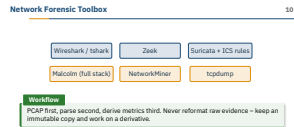
PCAP first, parse second, derive metrics third. Never reformat raw evidence – keep an immutable copy and work on a derivative.

2026-05-17

Industrial Security (Bachelor)
└ Exercises and Continuity

└ Network Forensic Toolbox

These are all free and run on commodity hardware — there is no excuse not to have at least Wireshark and a SPAN port on Level 2. Zeek is the workhorse for connection logs and protocol dissection; for ICS the community ICSNPP parsers give you S7, Modbus, DNP3, BACnet out of the box. Suricata with the Quickdraw or Dragos community rules catches the obvious signatures (unsolicited stop CPU, force coil), but never trust signatures alone — anomaly is more useful than IOC in OT. Malcolm packages all of this in a Docker stack, which is what the lab uses; the students should recognise it from earlier sections. The workflow rule is non-negotiable: hash the raw PCAP, store it read-only on a write-once medium, work only on copies. Reformatting raw evidence is how chain of custody dies in court.



- **Internal first:** plant operator, on-call engineer, executive sponsor.
- **External next:** CERT (BSI / CISA), sectoral ISAC, regulators.
- Templates for each audience: technical (engineering), operational (plant managers), executive (board), public (PR).
- Use a **single channel of truth** – e.g. war-room chat – to avoid contradictory updates.

Caution

Speculation kills credibility. Communicate *what you know* and *what you do not know* separately.

2026-05-17

Industrial Security (Bachelor) └ Exercises and Continuity

└ Communication Strategy

Order matters: internal stakeholders before external, because nothing destroys trust faster than the plant manager hearing about “their” incident from a journalist. The four audience templates exist because the same facts read very differently to an engineer (“Modbus function code 5 from 10.0.0.42”) versus a board member (“a remote write to a safety device that we blocked”). Single channel of truth is the lesson from every real incident — WhatsApp groups and side emails create three contradictory versions within an hour. The “what we know / what we do not know” rule is borrowed from aviation incident communication; it sounds obvious but takes discipline under stress. War story: one large utility lost more reputation from a contradictory press release than from the breach itself, because the CTO and CISO had not aligned. Tell them: silence is a decision too — the regulator notices when you go dark.

Communication Strategy

- **Internal first:** plant operator, on-call engineer, executive sponsor.
- **External next:** CERT (BSI / CISA), sectoral ISAC, regulators.
- Templates for each audience: technical (engineering), operational (plant managers), executive (board), public (PR).
- Use a **single channel of truth** – e.g. war-room chat – to avoid contradictory updates.

Caution
Speculation kills credibility. Communicate what you know and what you do not know separately.

1. Timeline of events with timestamps

2. What happened (root cause, contributing factors)

3. What worked / what did not

4. Action items with owners and due dates

5. Follow-up review date

Blameless

Focus on systems and decisions, never on individuals.

2026-05-17

Industrial Security (Bachelor)
└ Exercises and Continuity

└ Post-Mortem Template



Insist on the blameless culture point — it is the difference between learning and theatre. War story: one post-mortem after a HMI ransomware incident concluded “operator clicked a phishing link”; the company fired the operator and changed nothing, and the same class of incident happened nine months later because the underlying email gateway gap was untouched. A good post-mortem asks why the system allowed the click to reach a control-network asset in the first place. The five-section template is taken from Google SRE and works for OT too — the only OT-specific addition is that “what happened” must include the process-engineering view, not just the cyber view. Action items without owners and due dates are wishes; track them in the same tracker as production work, otherwise they vanish. Aim to publish within five working days while the details are still fresh and people still care.



Cadence depends on regulatory pressure (NERC CIP, KRITIS) and on the maturity of the team.

2026-05-17

These cadences are starting points, not commandments — a KRITIS operator under BSIG audit will be pushed harder than a small machine builder. Annual full-scale exercises are expensive (you pull operators off shift) but they are the only way to test cross-organisation coordination with the CERT and the regulator. Quarterly tabletops are cheap and high-value: two hours, a printed scenario, the on-call team in a room. Monthly drills can be as small as “restore the last historian backup to a sandbox and prove it boots” — short, repeated, muscle-memory. Continuous monitoring is the baseline: if you do not have it, the other cadences do not matter because you will not detect anything to respond to. Tie this back to the maturity model from Section 9: cadence should grow with the team’s ability to execute it without breaking production.

Exercise Cadence

Annual full-scale

Quarterly tabletop

Monthly drill

Continuous monitoring

Cadence depends on regulatory pressure (NERC CIP, KRITIS) and on the maturity of the team.

- Verify integrity of restored PLC programs against a signed baseline.
- Re-baseline alarms and trends – known-good snapshot before declaring “done”.
- Heightened monitoring window (e.g. 72 hours) after recovery.
- Capture lessons learned within 5 working days while details are fresh.

Don't rush

Premature “all clear” is how secondary incidents happen. The attacker may still be present.

2026-05-17

Industrial Security (Bachelor) └ Exercises and Continuity

└ Recovery Validation

This is the slide where most real recovery efforts fail — the pressure to “get production back” overrides verification. War story: after one ransomware event a European manufacturer re-stored the engineering workstations from backup and resumed production within 36 hours; nobody validated the PLC logic against a signed baseline, and the attacker’s persistence in a ladder-logic subroutine triggered a second outage two weeks later. Re-baselining alarms and trends matters because attackers sometimes tamper with setpoints in ways that only show up under load. The 72-hour heightened monitoring window is borrowed from FIRST CSIRT guidance and catches most “came back to finish the job” attempts. Lessons learned within five working days is not arbitrary — memory decays fast and people rotate off the incident, so the window for honest reflection is narrow. Underline the important box: “all clear” is a decision the plant manager makes on evidence, not a feeling the team has.

- Verify integrity of restored PLC programs against a signed baseline.
- Re-baseline alarms and trends – known-good snapshot before declaring “done”.
- Heightened monitoring window (e.g. 72 hours) after recovery.
- Capture lessons learned within 5 working days while details are fresh.

Don't rush

Premature “all clear” is how secondary incidents happen. The attacker may still be present.

★ Key Takeaway: What to remember from this section

- OT IR rules differ from IT IR – safety leads, visibility matters more than isolation.
- Forensics on PLCs is constrained; the network capture is the most valuable evidence.
- Regulators expect short reporting windows – 24 / 72 hours under NIS2.
- Tabletops surface gaps before incidents do; rehearse recovery, not just plans.

2026-05-17

Industrial Security (Bachelor)
└ Exercises and Continuity

└ Summary – Section 10

Closing beats: safety leads, the network capture is your forensic anchor, NIS2 turns reporting into a calendar problem you must solve before the incident, and a rehearsed recovery is the only kind that works. Bridge into the closing arc of the course: in Section 11 we look at standards (IEC 62443, ISO 27019, NIS2) that codify a lot of what we just discussed, so the IR plan does not live in isolation. Quick exit question for the class: pick one device on the lab bench — can you state its RTO, its RPO, and who would sign off on a restart after an incident? If three students cannot answer that, we have already justified the next section. Encourage them to bring real war stories to the next session — IR culture is built on shared experience, not slides.

★ Key Takeaway: What to remember from this section

- OT IR rules differ from IT IR – safety leads, visibility matters more than isolation.
- Forensics on PLCs is constrained; the network capture is the most valuable evidence.
- Regulators expect short reporting windows – 24 / 72 hours under NIS2.
- Tabletops surface gaps before incidents do; rehearse recovery, not just plans.

- NIST SP 800-61 Rev. 2. *Computer Security Incident Handling Guide*, 2012.
- NIST SP 800-86. *Guide to Integrating Forensic Techniques into Incident Response*, 2006.
- SANS. *Incident Handler’s Handbook*, multi-author white papers.
- Directive (EU) 2022/2555 (NIS2). *Article 23 – Reporting obligations*.
- CISA. *ICS-CERT Incident Response* resources.
- BSI. *IT-Grundschutz, baustein DER.2.3 (Notfallmanagement)*.
- Dragos. *ICS Incident Response Playbook* concepts (sector-specific).
- Idaho National Lab. *Cyber-Informed Engineering for Recovery*, 2022.
- ISO/IEC 27035 series. *Information security incident management*.
- Caltagirone, S., Pendergast, A., Betz, C. *The Diamond Model of Intrusion Analysis*, 2013.

2026-05-17

Industrial Security (Bachelor)
└ Exercises and Continuity

└ References – Section 10

- NIST SP 800-41 Rev. 3. *Computer Security Incident Handling Guide*, 2012.
- NIST SP 800-86. *Guide to Integrating Forensic Techniques into Incident Response*, 2006.
- SANS. *Incident Handler’s Handbook*, multi-author white papers.
- Directive (EU) 2022/2555 (NIS2). *Article 23 – Reporting obligations*.
- CISA. *ICS-CERT Incident Response* resources.
- BSI. *IT-Grundschutz, baustein DER.2.3 (Notfallmanagement)*.
- Dragos. *ICS Incident Response Playbook* concepts (sector-specific).
- Idaho National Lab. *Cyber-Informed Engineering for Recovery*, 2022.
- ISO/IEC 27035 series. *Information security incident management*.
- Caltagirone, S., Pendergast, A., Betz, C. *The Diamond Model of Intrusion Analysis*, 2013.

End of Section 10

Incident Response and Recovery

Questions and discussion

